

R401 – SAE 401

Jean-Luc Damoiseaux
IUT-Aix-Marseille
Dpt R&T



1

2

Plan

- R401-SAE 401
- Pare-feu
 - Types de pare-feu
 - Passerelle sécurisée (recommandation ANSSI)
 - Politique de filtrage (recommandation ANSSI)
- Certification CSNA
 - Généralités
 - Fonctionnement d'un pare-feu Stormshield
 - Topologie de travail

2

R401 – SAE 401

Infrastructures de sécurité

- **Équipements dédiés à la sécurité**
- Bases de cryptographie asymétrique (chiffrement asymétrique, certificats, signature, pki, ...)
- Services et applications sécurisées (**SSL, HTTPS, ...**)
- Architecture réseau sécurisée (**DMZ, proxy, reverse-proxy, ...**)
- Approfondissement des mécanismes de filtrage et de contrôle d'accès (**Proxy-Firewall, NAT, ACL...**)
- **Tunnels VPN**

3

PARE-FEU

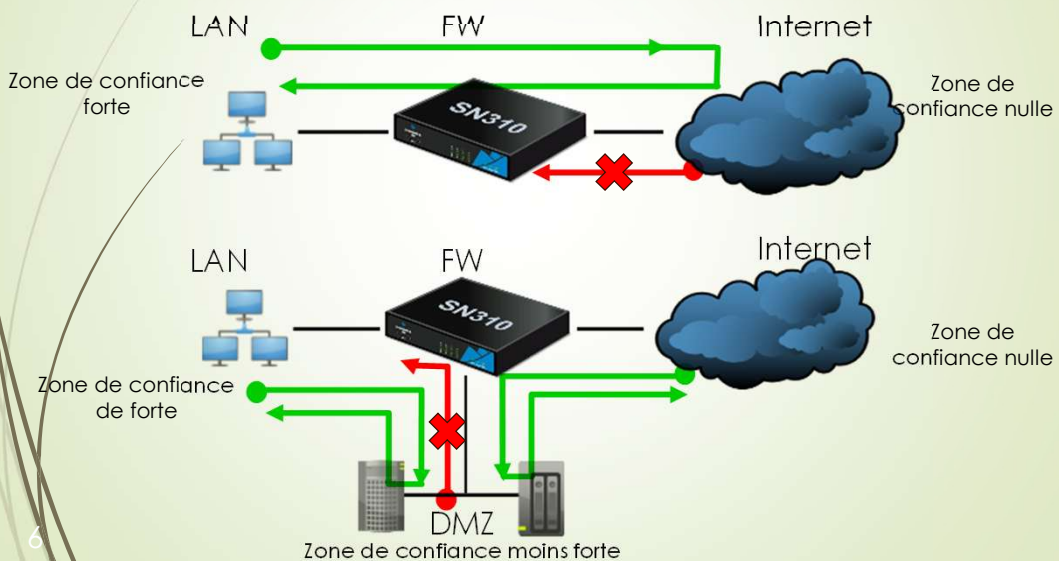
Types de pare-feu

4

Définitions

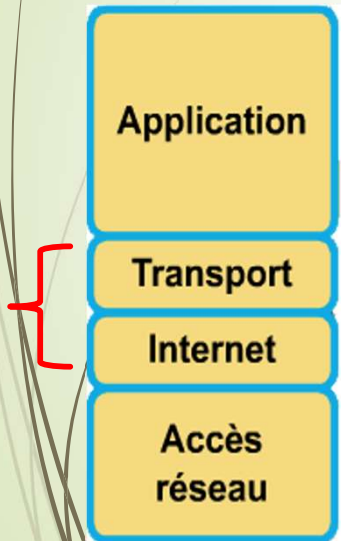
- Un pare-feu est à minima un élément logiciel ou matériel réglementant les droits de passage des connexions entre des correspondants situés dans des zones physiques séparées par celui-ci
- Un pare-feu met en œuvre une politique de sécurité définie par une matrice de flux

Schémas classiques d'utilisation



7

Pare-feu – sans état (stateless)



Chaque analyse est indépendante de la précédente

- Conformité d'un paquet IPv4 ou IPv6
- Adresses IP source et destination
- Conformité du segment TCP / datagramme UDP
- Numéro du port

7

8

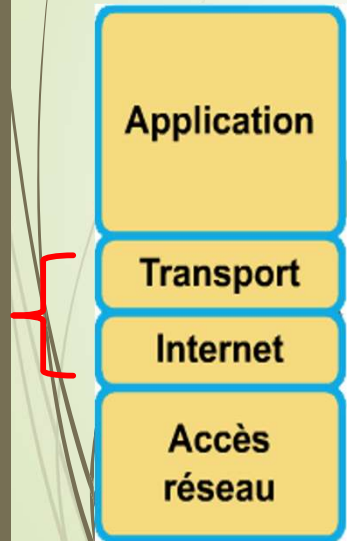
Cas d'un accès HTTP



8

9

Pare-feu avec états (statefull)



Assure dans le temps le suivi de l'état des connexions pour les flux TCP, UDP, ICMP entrants et sortants

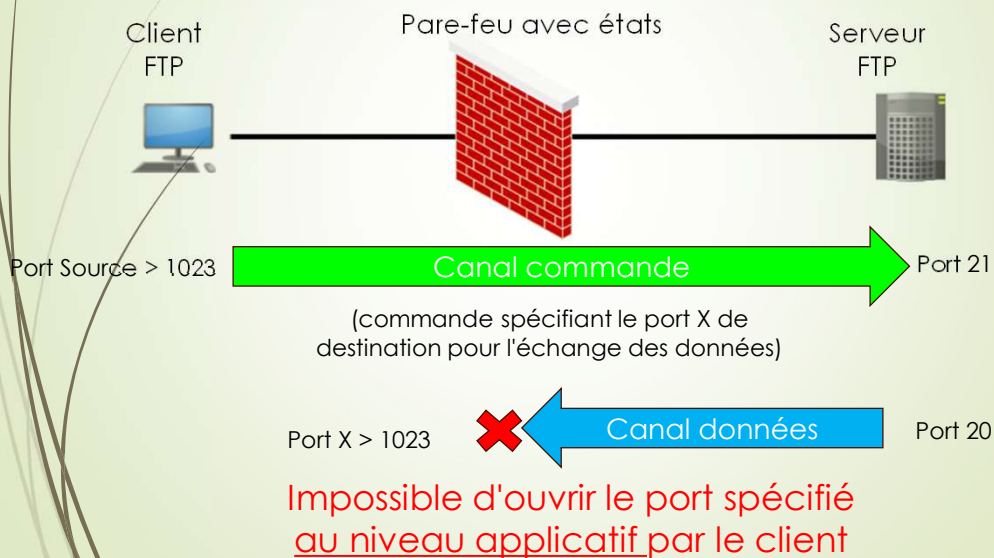
Gère dans le temps les attributs de chaque connexion :

- adresses IP et ports impliqués
- numéros de séquence
- flag TCP (SYN, ACK, ...)

9

10

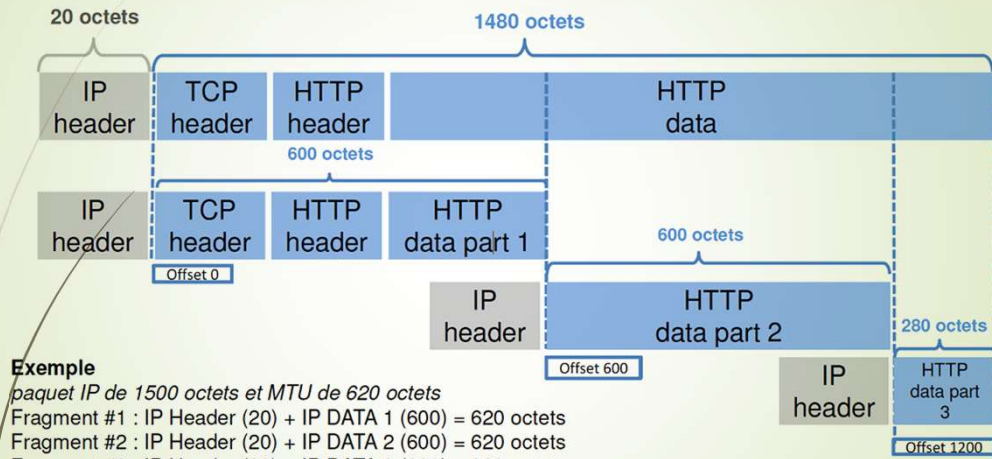
Cas d'un serveur FTP mode actif



10

11

Principe de la fragmentation



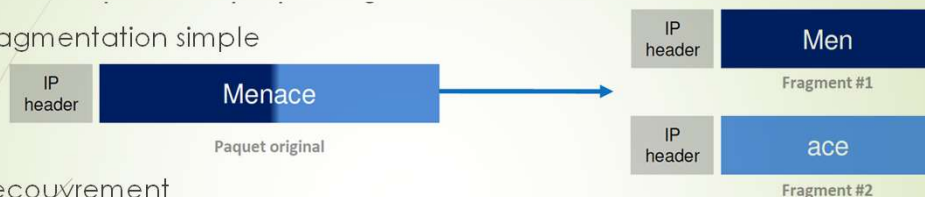
Les fragments sont réassemblés chez le destinataire !

11

12

Attaque par fragmentation

Fragmentation simple



Recouvrement



12

13

Attaque couche applicative

- Code HTML/CSS litigieux

<http://www.monserveur.org/répertoire/cmd%252Eexe>

%252E -> %2E -> caractère '.'

<http://www.monserveur.org/répertoire/cmd%252Eexe>

- Code javascript malveillant

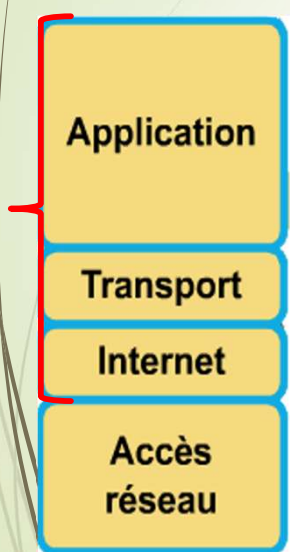
"AttМxxxk".replace("x", "") → "Att)ck" → "Att)ck"

"Attackee".split("e")[0] → "Attack"

13

14

Pare-feu - Applicatif

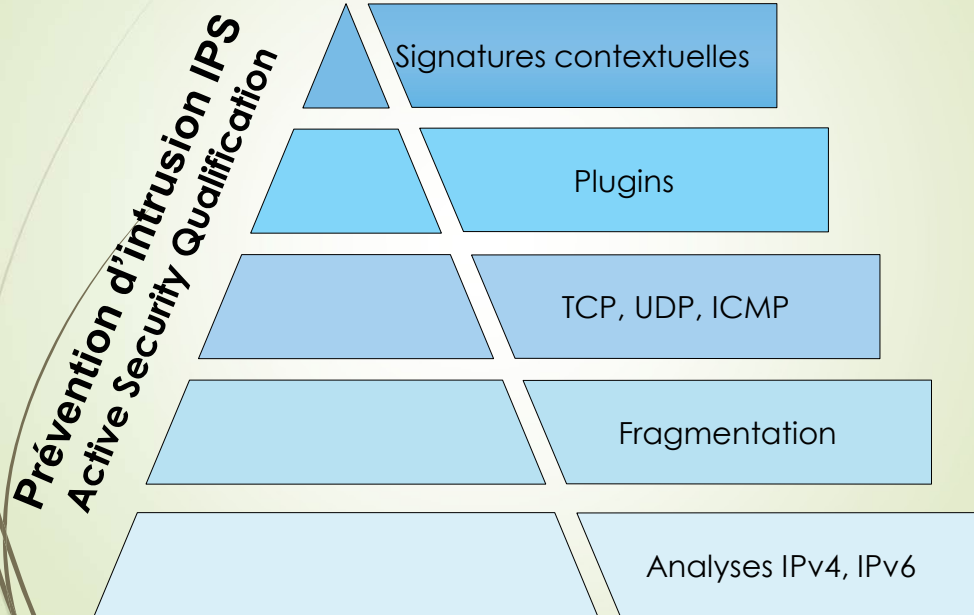


Vérification complète de la conformité du paquet à un protocole attendu

Chaque type de pare-feu inspecte un nombre limité d'applications grâce à des modules/plugins

14

15



15

16

Certification VS Qualification

- Un pare-feu certifié est un produit de filtrage des flux réseau dont la robustesse a été évaluée par un laboratoire indépendant
- Un pare-feu qualifié est un pare-feu certifié et pour lequel l'éditeur a réussi le processus de qualification du produit établi par l'ANSSI (donc recommandé par l'état)

16

PARE-FEU

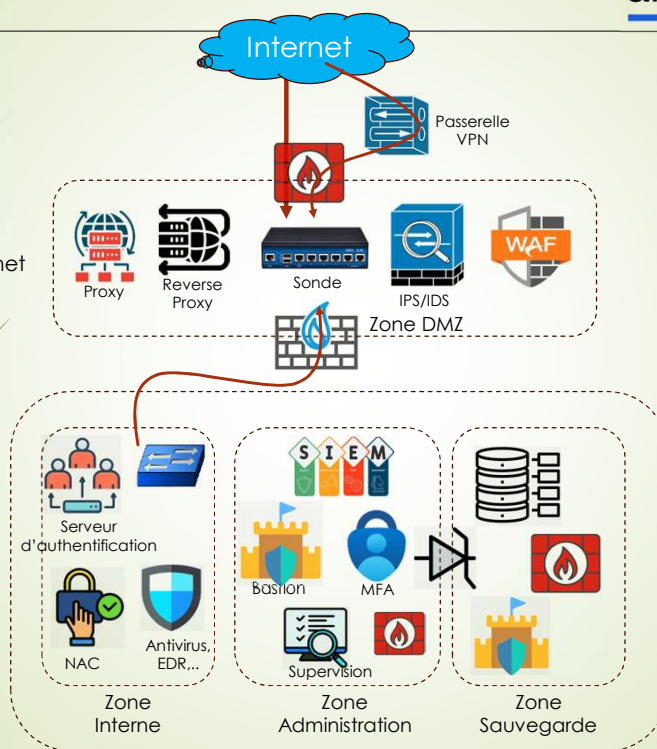
Passerelle internet sécurisé

17

Dpt R&T – JLD

18

Passerelle internet
sécurisée



18

19

Recommandations de l'ANSSI

- Utiliser des pare-feux de marques différentes
 - + Limite l'exploitation d'une vulnérabilité intrinsèque
 - + Apporte de la complémentarité dans les fonctionnalités
 - Oblige à maîtriser plusieurs technologies
- Limiter les firewalls à leur fonction de filtrage
- Préférer
 - l'utilisation de pare-feu physiques à des pare-feux virtuels
 - des pare-feux qualifiés

19

PARE-FEU

Politique de filtrage

20

21

Principes généraux du filtrage

- Les règles de filtrage sont évaluées séquentiellement
- A un flux est associé une règle de filtrage unique
- Il faut définir précisément les flux ayant pour origine ou destination le pare-feu
- Il convient de journaliser toutes les règles

21

22

Plus précisément - I

A destination du pare-feu - Action : **Autoriser**

- les services d'administration (`ssh`, `https`)
- les services de supervision de la passerelle (`get-snmp`)

Emis par le pare-feu - Action : **Autoriser**

- les services d'envoi de journaux (`syslog`)
- les services d'alerte (`trap-snmp`)
- services permettant le maintien en condition opérationnelle (par exemple les flux de sauvegarde).

Protection du pare-feu - Action : **Interdire**

- tous les flux à destination des interfaces du pare-feu

22

Plus précisément - II

Flux métiers - Action : **Autoriser**

- Regroupement des règles en fonction des entités métiers auxquelles elles ouvrent des services (comptabilité, ressources humaines)
- Regroupement des règles en fonction des services offerts (navigation internet, accès aux proxy, accès aux bases de données)

Interdiction finale - Action : **Interdire**

Tous les flux en provenance de n'importe où et à destination de n'importe où

- Règle souvent implicite mais rarement journalisée
- L'ajout d'une règle explicite d'interdiction finale journalisée garantit l'application du modèle de sécurité positif (tout ce qui n'a pas été autorisé précédemment est interdit) et permet de conserver la trace des flux non légitimes

23

Dpt R&T – JLD




24

FILTRAGE
NAT

Rechercher...

+ Nouvelle règle
✕ Supprimer
↑ Monter
↓ Descendre
Tout dérouler
Tout fermer
Couper
Copier
Coller

	État	Action	Source	Destination	Port dest.	Commentaire
Flux à destination du pare-feu						
1	on	passer	srv_administration	Firewall_admin	https firewall_srv ssh	20130102 Accès au pare-feu depuis le serveur d'administration
2	on	passer	srv_sauvegarde	Firewall_admin	ssh	20130102 Accès au pare-feu depuis le serveur de sauvegarde
3	on	passer	srv_supervision	Firewall_admin	snmp	20130102 Accès au pare-feu depuis le serveur de supervision
Règle de protection du pare-feu						
4	on	bloquer	Any	Firewall_all	Any	20130102 Règle de protection du pare-feu
Flux métiers						
-- Flux d'accès aux serveurs métiers						
----- Flux d'accès aux serveurs métiers de la comptabilité						
5	on	passer	net_jan_compta	srv_metier1_compta	https	20130104 Accès au serveur metier n°1 de la comptabilité
6	on	passer	net_jan_compta	srv_metier2_compta	http	20130104 Accès au serveur metier n°2 de la comptabilité
----- Flux d'accès aux serveurs métiers des ressources humaines						
7	on	passer	net_jan_rh	srv_metier_rh	https	20130104 Accès au serveur metier des ressources humaines
-- Flux d'accès aux serveurs DNS						
8	on	passer	grp_jan	grp_dns_interne	dns_udp	20130104 Accès aux serveurs DNS depuis les réseaux utilisateur
Règles d'interdiction antiparasites						
9	on	bloquer	grp_jan	ip_broadcast	netbios-ns_udp netbios-dgm	20130103 Suppression du trafic de broadcast utilisateur
Règle d'interdiction finale						
10	on	bloquer	Any	Any	Any	20130102 Règle d'interdiction finale

24

CSNA

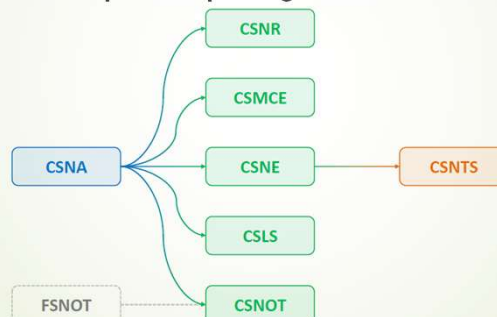
Généralités

25

26

Buts

- Compléter vos connaissances en cyber-sécurité par la découverte d'un équipement qualifié et assurant une gestion unifiée des menaces (UTM - Unified Threat Management)
- Passer la certification CSNA
La note obtenue au premier passage sera votre note de SAE !



- En cas de réussite, être inscrit au concours Springbrain (<https://www.stormshield.com/fr/spring-brain/>) le 13 mai 2026 à 18h

26

27

La certification CSNA

- Reconnue par l'ANSSI
- Coût pris en charge par l'IUT (en industrie $\geq 2000\text{€}$)
 - Compte sur le site Stormshield, Accès aux supports de cours et à l'environnement virtuel
 - 2 passages d'examen (le premier forcément à l'IUT) ; QCM environ 1H30 avec support de cours ; succès si score $\geq 70\%$
- Tout à fait possible en auto-formation
 - Le guide de formation est "gros" mais clair
 - les TPs sont réalisables sous l'environnement virtualbox fourni ou sur QAMU

27

28

Contenu de la formation

1. Présentation des certifs, de Stormshield, etc.
 2. Prise en main du FW
 3. Traces et supervisions
 4. Les objets (TP2 durée estimée 30-45mn)
 5. Configuration réseau (TP3 durée estimée 30-45mn)
 6. Translation d'adresses (TP4 durée estimée 1h-1h30)
 7. Filtrage (TP5)
 8. Protection applicative (TP6)
 9. Utilisateurs & Authentification (TP7)
 10. VPN (surtout IPsec) (TP8)
 11. VPN SSL (TP9)
- } (TP1 durée estimée 45mn)

28

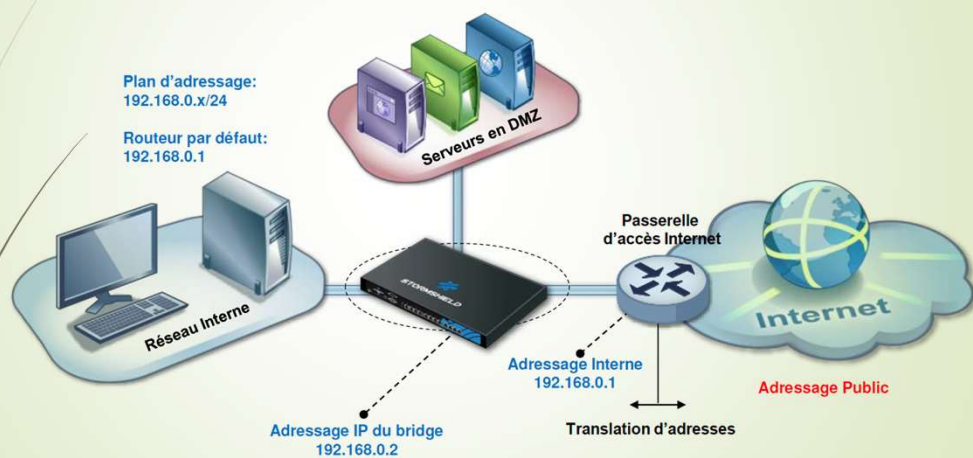
CSNA

Fonctionnement d'un parefeu Stormshield

29

30

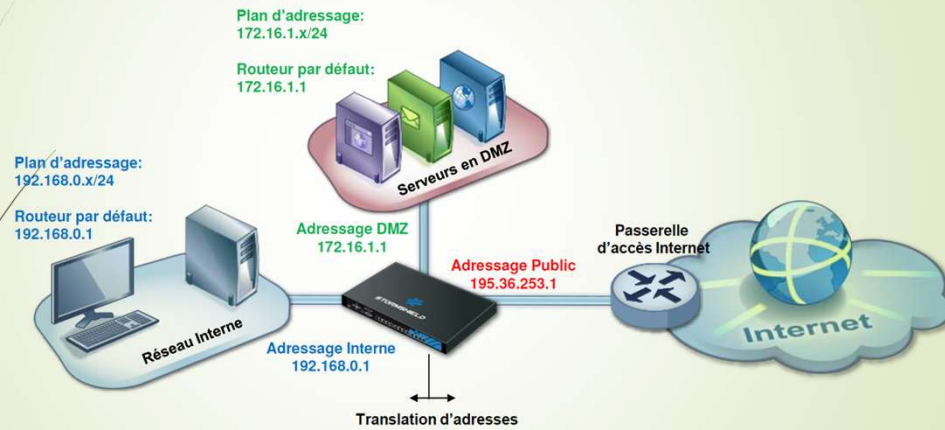
Fonctionnement mode Bridge



30

31

Fonctionnement – mode Routeur



31

32

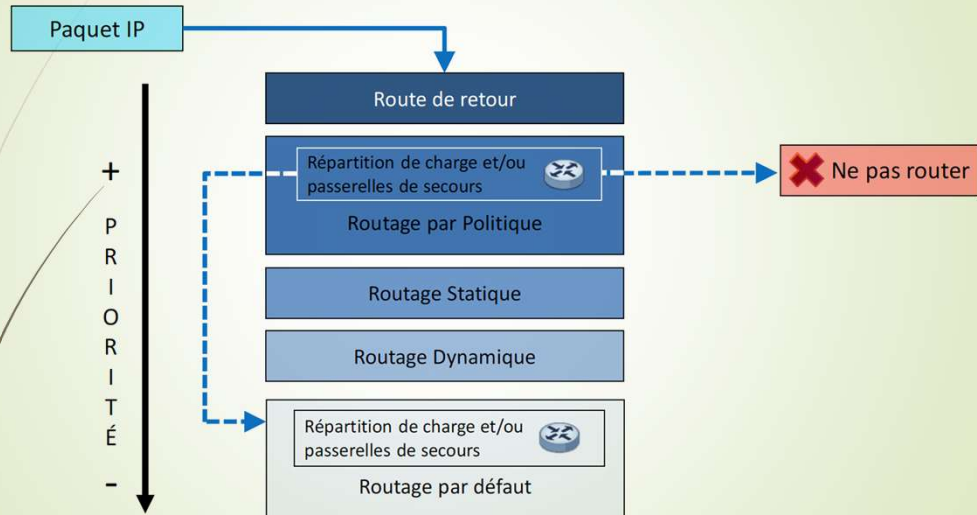
Notion d'objet

- Tout est objet (facilite la manipulation et le changement des valeurs)
 - **Nom**
 - **Valeur** et Description
- Catégories des objets
 - Préconfiguré (port, réseaux, etc.)
 - Implicite (créé automatiquement par le FW lors de sa configuration par l'administrateur)
 - Créé par l'administrateur
- Types des objets
 - Objet réseaux (@IP, n° port, FQDN, etc.)
 - Objets WEB (groupe d'URL, ...)
 - Certificats et PKI (étudiés en CSNE)

32

33

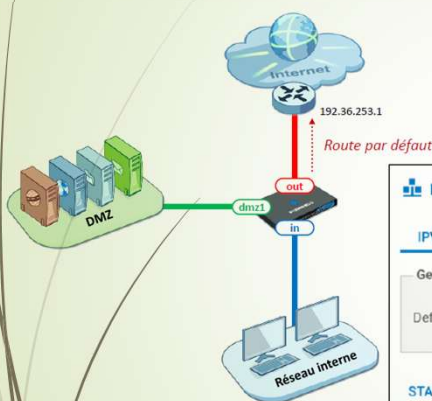
Routage



33

34

Routage par défaut



NETWORK / ROUTING

IPV4 STATIC ROUTES **IPV4 RETURN ROUTES**

General

Default gateway (router)

STATIC ROUTES

Searching...

Status	Des
Host	Object name: gw_default
Network	IPv4 address: 192.36.253.1
Address range	MAC address: 01:23:45:67:89:ab (optional)

CREATE AN OBJECT

34

Dpt R&T – JLD

35

amU Aix Marseille Université

IUT

Routage statique

NETWORK / ROUTING

IPV4 STATIC ROUTES IPV4 RETURN ROUTES

General

Default gateway (router) gw_default

STATIC ROUTES

Status	Destination network (host, network...)	Interface	Address range	Gateway
on	net_b_in	sites	192.168.2.0/24	fw_b
on	net_c_in	sites	192.168.3.0/24	fw_c
on	net_d_in	sites	192.168.4.0/24	fw_d

35

JL Damoiseaux
- Dpt R&T

36

amU Aix Marseille Université

IUT

Filtrage & Translation d'adresses

Paquet initial

P R I O R I T É

0	Filtrage implicite	Passer	Bloquer
1	Filtrage global	Passer	Bloquer
2	Filtrage local	Passer	Bloquer
3	NAT implicite	Passer	Aucune règle
4	NAT global		
5	NAT local		

Bloquer

36

Filtrage

- Assuré par des règles définissant
 - Les flux à surveiller
 - La nature de l'action (autorisé, bloqué, tracé, etc.)
 - Type d'inspection de sécurité (IPS, IDS, Firewall)
- Suivi statefull des connexions => pas la peine d'écrire la règle correspondant au flux retour d'une connexion établie au travers du firewall

37

Filtrage – Menu et ordre d'application des règles

SECURITY POLICY / FILTER - NAT

(6) Training lab Edit Export

FILTERING NAT

Searching...

	Status	Action	Source	Destination	Dest. port	Protocol	Security inspection
1	on	pass	Network_in	Internet	http	udp	IPS
2	on	pass	Network_internals	Internet	Any		IPS
3	on	pass	Network_internals	Internet geo France	Any		IPS
4	on	pass	Internet	Firewall_Lout	http		IPS

« < | Page 1 of 1 | > »

CHECKING THE POLICY

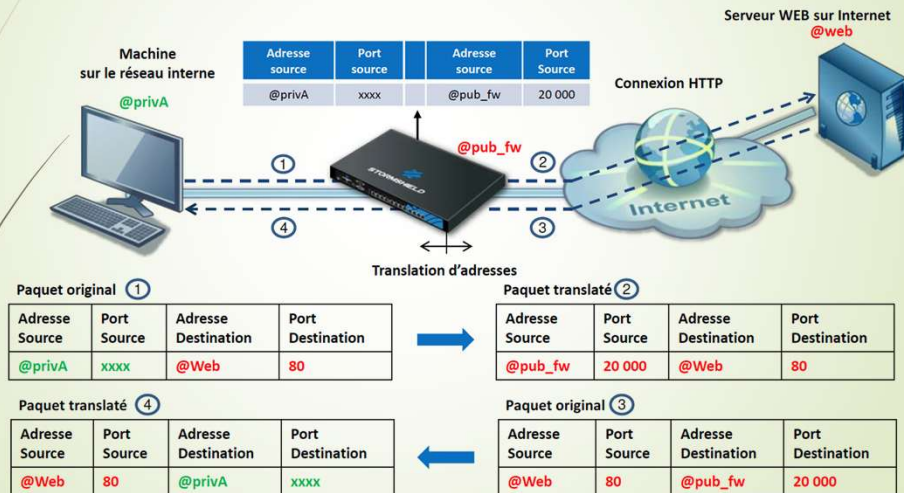
- ✖ [Rule 1] The destination port 'http' uses an IP that is incompatible with the value of the protocol column
- ⚠ [Rule 3] This rule will never be applied as it is covered by the rule 2.
- ⚠ [Rule 4] The rule has a dynamic address of the firewall as destination but no interface is specified.

CANCEL APPLY

38

39

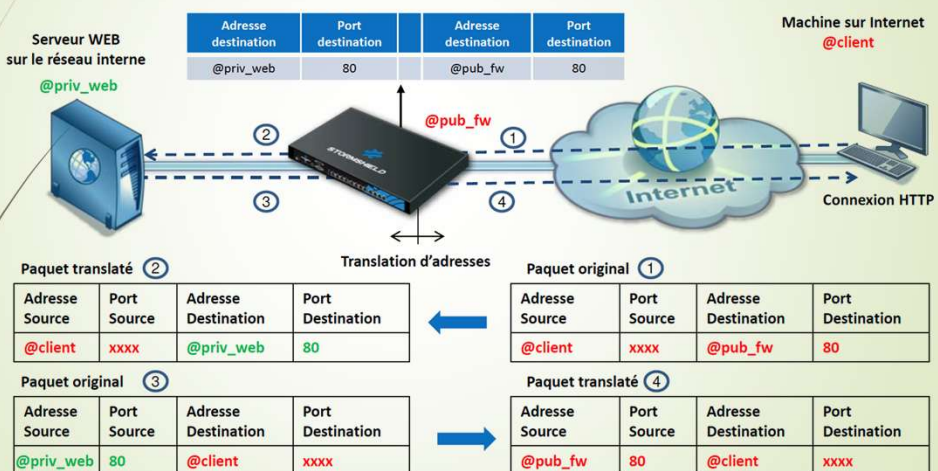
Translation d'adresses dynamique (Masquerading)



39

40

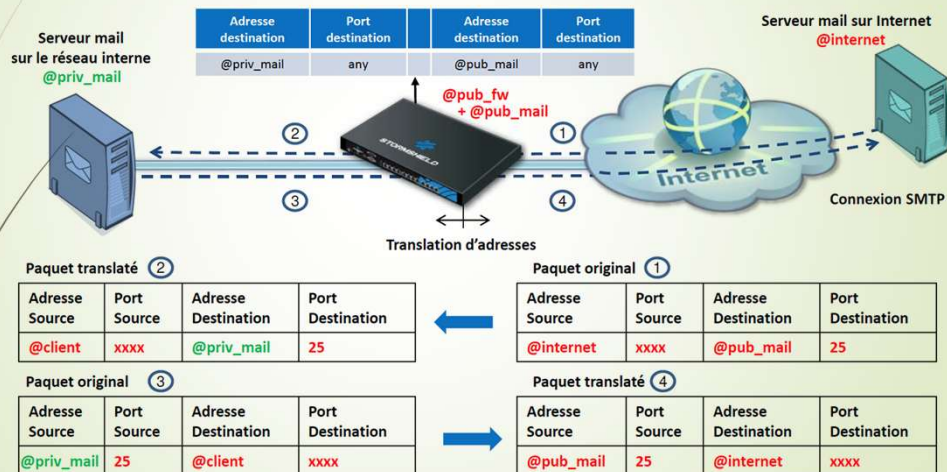
Translation d'adresses statique par port



40

41

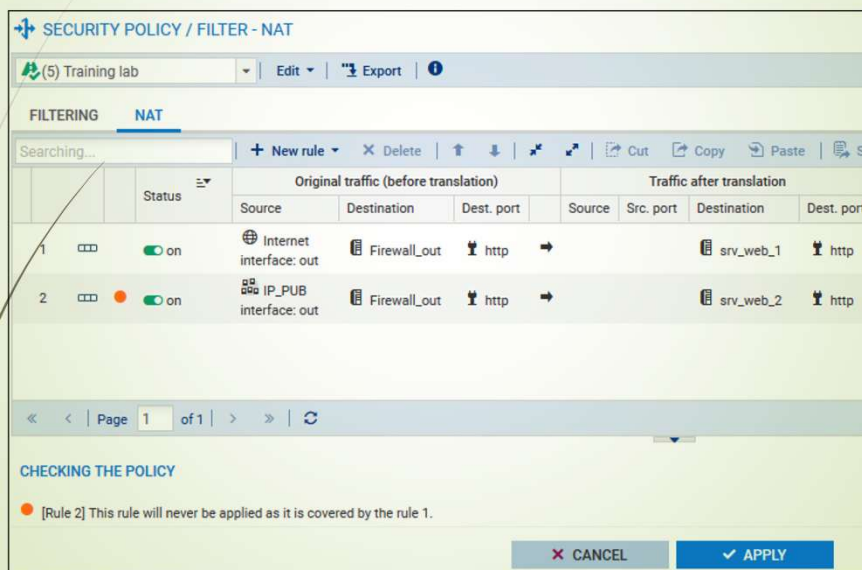
Translation d'adresses statique (externalisation de serveur - bimap)



41

42

Translation d'adresses – Menu et ordre d'application des règles



42